

Project Description

For my project, I decided to focus on **OWASP Top 10 attacks** as the main attack surface category. To conduct controlled and ethical testing to identify potential weaknesses related to the OWASP Top 10, I am using a collection of powerful, open-source security tools. These tools help in mapping the attack surface, identifying vulnerabilities, and collecting information required to demonstrate OWASP Top 10 risks.

Below is the list of tools selected for the project:

Tools Used in the Project

1. Nuclei

A fast vulnerability scanner that uses templated-based checks to detect misconfigurations, security issues, and CVEs across web applications and network assets.

2. Naabu

A high-speed port scanner that identifies open ports on a target using SYN-based scanning. It helps determine the exposed services that could lead to OWASP Top 10 vulnerabilities.

3. Httpx

An HTTP probing tool used to identify running web services, capture status codes, titles, technologies, redirects, and more. Helps in fingerprinting targets discovered during recon.

4. Subfinder

A subdomain enumeration tool that discovers valid subdomains using passive sources. Useful for identifying additional attack surfaces.

5. Amass

An advanced asset discovery tool that maps out subdomains, infrastructure, and relationships for a target domain.

6. Assetfinder

A domain asset discovery tool that quickly finds subdomains and related assets linked to the target.

7. Sublist3r

A fast subdomain enumeration tool that uses multiple public search engines and sources to gather subdomains.

8. CTL (Common Tool Library)

A lightweight recon toolset used for performing various reconnaissance tasks efficiently.

9. GAU (Get All URLs)

Fetches archived URLs from sources like Wayback Machine and Common Crawl, helping identify hidden endpoints.

10. Katana

A fast web crawling tool designed to collect endpoints, URLs, JS files, and parameters for deeper analysis.

11. GoSpider

A web spider that recursively crawls web applications to extract internal and external URLs for testing.

12. FFuf

A fast web fuzzer used for directory brute forcing, parameter discovery, and endpoint enumeration.

13. CeWL

A custom wordlist generator that crawls a target website to build wordlists for credential attacks or dictionary-based testing.

14. DNSx

A fast DNS resolver and DNS-based validation tool used to resolve and verify large sets of subdomains.

15. ShuffleDNS

A mass DNS brute forcing tool that combines resolvers and wordlists to discover valid DNS records for the target.